Sprint 4 Static Analysis Report

Asiah Krier & Israel Mora | Ripple / music_discovery | November 6, 2026

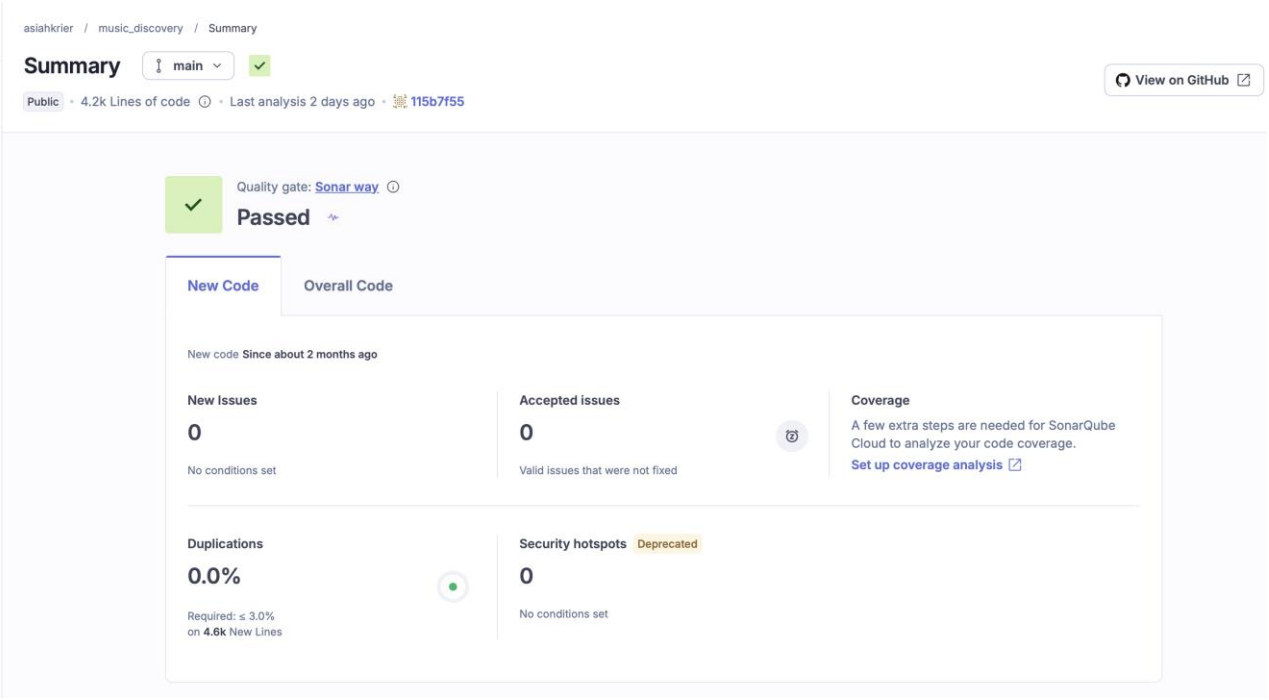
1. Tools Used

Programming languages: JavaScript/JSX, HTML and CSS, SQL is also used for certain functions. SonarQube Cloud analyzes source quality and security. Trivy scans dependency manifests and lockfiles through GitHub Actions. The supplied artifact records Trivy version 0.70.0.

2. Required Metrics

SonarQube - main branch

Latest verified analysis: November 4, 2026 at 11:02 PM CST. Commit 115b7f55836ce9f734caaeccf8795665d8031a2f. The Quality Gate passed.



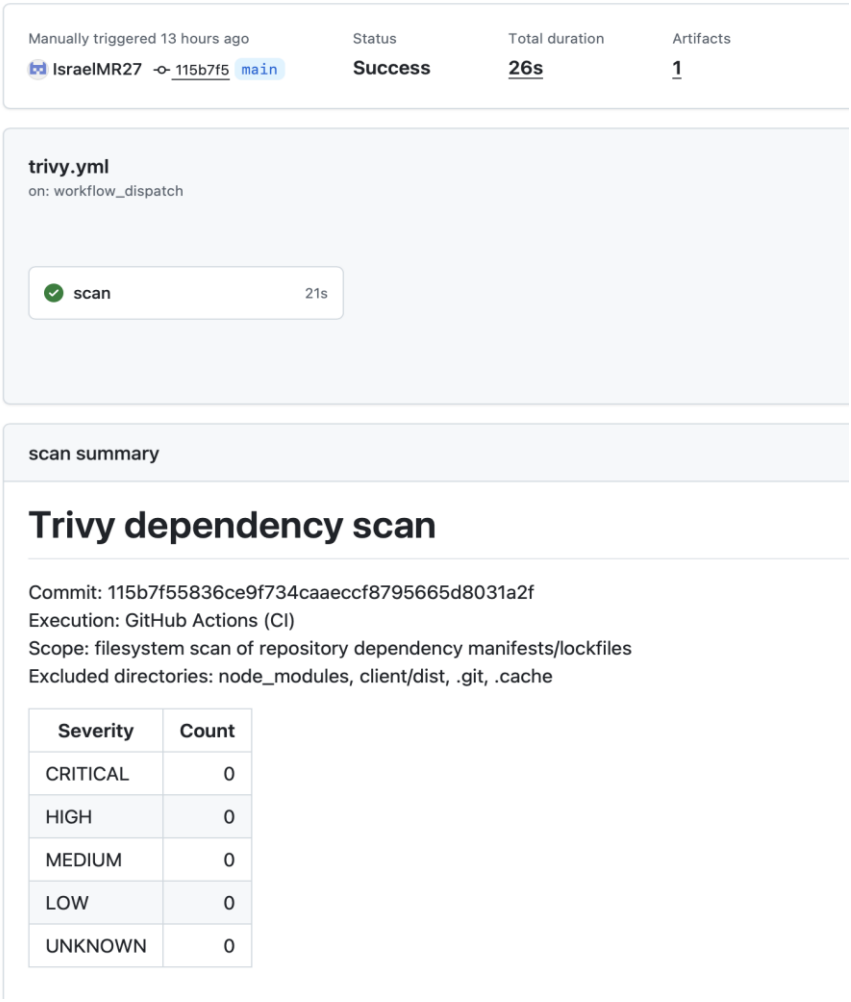
Metric	Result
Bugs	0
Vulnerabilities	0
Code Smells	0
Security Hotspots	0
Quality Gate	0

Evidence: SonarQube main dashboard. Metrics and Quality Gate were retrieved November 6. A passing gate does not establish complete test coverage.

2. Required Metrics continued

Trivy - main branch

The supplied GitHub Actions run produced its artifact November 6, 2026 at 9:42 PM CST. Scanned commit: 115b7f55836ce9f734caaeccf8795665d8031a2f. This matches the SonarQube main analysis revision.



Evidence: Main-branch Trivy run and artifact. Counts were checked against trivy-summary.md and trivy-results.json; scanner version came from trivy-version.txt.

3. Scope

SonarQube: main-branch project asiahkrier_music_discovery, with 4,214 analyzed lines of code. Findings apply to the configured analysis scope.

Trivy: filesystem vulnerability scan of repository dependency manifests and lockfiles. Excluded directories: node_modules, client/dist, .git and .cache. Zero findings mean no vulnerabilities reported by this scan/database snapshot.

The report records final main-branch results. Runtime notices and build-size advisories are separate from vulnerability counts.

4. Trend

Previous refers to Sprint 3. This Sprint refers to Sprint 4. Changes shows the difference between the two sprints.

Measure	Previous	This Sprint	Changes
Bugs	0	0	0
Vulnerabilities	0	0	0
Code smells	0	0	0
Trivy CRITICAL and HIGH	0	0	0

All four measures remained at zero from Sprint 3 to Sprint 4. These are final scan results, not counts of every issue identified and fixed during development. As any issues appear on SonarQube and the Trivy scans when we do new PRs, we fix them in either a new commit on the same PR or we do a whole new PR to address the issues.

5. Reflection

Sprint 4 added account settings, live signup validation, search suggestions, personalized Ripple mixes, and microgenre discovery. The mix evolved to use saved Ripple songs and artists without requiring a personal Spotify connection. Catalog caching and smaller request batches addressed rate-limit problems.

The most problematic area this sprint was the new Ripple Mix code: it added duplicated code (10.6% on PR #37, above the 3% limit) and several maintainability warnings, which were fixed by moving shared code into mix-shared.js and fake-supabase.js before merging.

Quality work corrected asynchronous Promise handling, complex control flow, accessibility markup and other SonarCloud findings. Runtime and dependency updates addressed security advisories. Removing obsolete account-connection code and refreshing documentation helped keep implementation and documentation aligned.

The final main-branch Quality Gate passes and Trivy reports zero vulnerabilities. Next sprint we will keep fixing SonarQube findings before merging each PR, reuse shared helpers instead of copying code, and set up test coverage reporting in SonarQube.

Fix evidence: PR #31, PR #37, PR #38, and PR #46. Baseline: Sprint 3 static analysis report.

Required Statement

This static analysis was generated using automated tools during this sprint.